📌 【小南题解】AP 令和4年秋期 午後問1（信息安全／情報セキュリティ）

> **主题**：恶意软件 Emotet 机制分析、SaaS/邮件安全（SPF/DKIM）、DNS 攻击与 EDR 端点响应
>
> **考点标签**：`情報セキュリティ` `EDR` `DNSリフレクション攻撃` `SPF` `ICMPエコー` `ポートスキャン`
>
> **难度系数**：⭐⭐⭐☆☆（AP 午后信息安全核心必考题）

> 💡 **导读**
> 本题以近年来危害极其严重的 **Emotet 恶意软件** 为真实原型，全方位考查了 **“宏病毒邮件传播 ──► DNS 反射攻击与 SPF 认证缺陷 ──► 内网横向探索（ICMP/SYN 扫描）──► EDR 端点响应与隔离”** 的完整攻防链条。
> 搞懂这道题，你就能一口气吃透 AP 考试中关于 **SPF 认证的漏洞局限、DNS 放大攻击原理** 以及 **EDR 的自动化响应（端末隔離）** 三大核心考点！

🏢 1. 业务背景与网络架构全景图

📊 P 社网络架构与安全设备分布

安全区域 / 节点	部署设备 / 服务	关键作用与配置策略
网络边界	**FW（防火墙）**	控制 DMZ 与内部 LAN 间的通信，采集日志并遮断非授权连接。
DMZ 区域	**外部 DNS 服务器** **邮件中继服务器** **代理服务器（Proxy）**	- 外部 DNS 开启缓存功能 *(存在 DNS 反射攻击踏板风险)*。 - 邮件中继服务器执行 **SPF 发信源认证**。

内部 LAN	**内部 DNS / 社内邮件服务器** **顾客服务器 / 配布服务器**	- 配布服务器负责向 PC 分发验证过的 OS 补丁。 - PC 每日定时更新病毒定义库。
验证 LAN	**验证用服务器 & PC**	用于新补丁上线前进行为期 1 周的兼容性测试。

🧩 2. 逐题解构与破题要领

🔷 設問 1：安全对策现状与网络设备填空

(1) 填空 [a] [b] [c]：填充网络安全设备

- **题目破题：**
  - **[a]**：位于 Internet、DMZ、内部 LAN 交界处，负责业务通信许可与日志采集 ──► **FW（ファイアウォール）**。
  - **[b]**：执行 **SPF 认证** 验证发信源域名是否被伪造。因为验证的是从外部发往社内的邮件，应由 DMZ 的 **メール中継サーバ（邮件中继服务器）** 负责。
  - **[c]**：测试通过后，向终端 PC 注册并统一推送 OS 安全补丁的服务器 ──► **配布サーバ（补丁分发服务器）**。
- ✅ **标准答案：** `a：ア（FW）`，`b：ケ（メール中継サーバ）`，`c：ク（配布サーバ）`

(2) 选择题 ①：DNS 踏板攻击类型

- **题目破题：**
  外部 DNS 服务器在 DMZ 中开启了 **キャッシュサーバ（缓存服务器）** 功能且未限制访问。攻击者利用开放式递归查询，向其发送大量请求并把源 IP 伪造为目标受害者，利用巨型应答包压垮目标。
- **逻辑推导：**
  这种利用大量开放 DNS 缓存服务器作为踏板（Amplification）反射成倍放大流量的 DDoS 攻击被称为 **DNS リフレクション攻撃（DNS 反射攻击 / DNS Amp 攻击）**。
- ✅ **标准答案：** `ア`

🔷 設問 2：恶意软件 X（Emotet）行为调查

(1) 问答题 ②：ICMP エコー要求（Ping）能获取什么信息？（20 字以内）

- **题目破题：**
  恶意软件入侵 PC 后，向网段内所有 IP 连续发送 **ICMP エコー要求パケット（ICMP Echo Request）**。
- **逻辑推导：**
  ICMP Echo Request 相当于 Ping 命令。若收到 Echo Reply，说明该 IP 对应的主机在线且网络正常。恶意软件借此获取内网活跃主机的 IP 地址。
- ✅ **标准答案（字数比对）：**

  > `稼働中のホストのIPアドレス`（14 字）

(2) 选择题 ③：送信 TCP SYN パケット 的目的

- **题目破题：**
  恶意软件向探测到在线的主机发送带指定端口号的 **TCP SYN パケット** 并观察响应。
- **逻辑推导：**
  如果目标返回 `SYN/ACK`，说明该端口对应的服务正在运行。这属于 **ポートスキャン（端口扫描）**，目的是寻找开放端口以利用服务漏洞。
- ✅ **标准答案：** `ウ`（攻撃対象のサービスの稼働状態を知るため）

(3) 选择题 ④：为何 SPF 认证无法发现社外 PC 发来的恶发邮件？

- **题目破题：**
  从被感染的社外合作方 PC 发来的恶意邮件，SPF 机制为何无法拦截？
- **逻辑推导：**
  SPF 仅验证发信服务器 IP 是否与域名 DNS 发布的 SPF 记录一致。社外 PC 感染 Emotet 后，利用其正规的邮件客户端/服务器发送邮件，**发信域名与实际发信 IP 是完全匹配的（未发生域名伪造）**。因此 SPF 判定为合法邮件。
- ✅ **标准答案：** `ア`（送信者のドメインが詐称されたものでないから）

🔷 設問 3：EDR 系统引入与应急响应对策

(1) 问答题 ⑤：检知到何种现象可怀疑恶意软件 X 侵入？（25 字以内）

- **题目破题：**
  EDR 的 Agent 监控 PC 进程与通信。在入侵初期，恶意软件产生的何种异常行为最容易被捕获？
- **逻辑推导：**
  普通办公 PC 正常情况下绝不会向内网大量 IP 连续发送 Ping 包。连续发送 ICMP Echo Request 是内网横向探索（Lateral Movement）的典型征兆。
- ✅ **标准答案（字数比对）：**

  > `ICMPエコー要求パケットの連続した送信`（20 字）

(2) 问答题 ⑥：阻断内网探索的紧急处置措施是什么？（25 字以内）

- **题目破题：**
  当 EDR 检测到异常横向扫描时，为了防止恶意软件在内网扩散及向外网 C&C 服务器传出数据，EDR 应自动对该 PC 采取什么处置？

> ⚠️ **小南避坑硬核提醒**
> 绝对不要写“拔掉网线（LANケーブルを引き抜く）”！
>
> 1. 下线处置是由 **EDR 软件 Agent 自动执行** 的。
> 2. 拔网线无法处理 Wi-Fi 无线连接的终端。
>   正确表述应为逻辑上的 **终端网络隔离**。

- ✅ **标准答案（字数比对）：**

  > `マルウェアに感染したPCを隔離する`（17 字）

(3) 问答题：受害发生后，快速弄清被害内容应实施什么？（20 字以内）

- **题目破题：**
  EDR 引入后若不幸发生安全事件，如何利用 EDR 的特性快速摸清受害范围与数据泄露情况？
- **逻辑推导：**
  EDR 的管理服务器集中保存了各 Agent 上报的“命令执行、通信内容、文件操作”等

日志。通过分析这些日志可以还原攻击路径与受害范围。

- ✅ **标准答案（字数比对）：**

> `EDRが保存するログの分析`（13 字）

📝 3. 考点总结卡片（Exam Cheat Sheet）

```
### 🎯 AP 午后情報セキュリティ 核心考点总结

1. **SPF 认证的局限性**：
   - SPF 只能防“域名伪造（なりすまし）”。
   - 若合法账号/终端被盗用或感染（如 Emotet），由于使用正规发信服务器，SPF 无法拦截！

2. **内网探索（横断／Lateral Movement）两大步**：
   - 第一步（找活人）：ICMP エコー要求（Ping Sweep）⟶ 获取在线 IP。
   - 第二步（找漏洞）：TCP SYN パケット（Port Scan）⟶ 确认开放服务与端口。

3. **EDR vs 传统杀毒软件（アンチウイルス）**：
   - 传统杀毒：基于特征码（パターンマッチング），防“已知”入侵。
   - EDR：基于行为监控（挙動監視），做“入侵后”的自动隔离（端末隔離）与日志溯源。
```